

COMPTE RENDU DE TP

B3 TP2.3 – Test d'intrusion : Phase I – Reconnaissance

Xavier Sionnet – BTS SIO – 29 septembre 2026

1. Objectif du TP

L'objectif de ce TP est de comprendre la **phase de reconnaissance** d'un test d'intrusion : récolter un maximum d'informations sur une ou plusieurs cibles, puis les documenter avec méthode afin de pouvoir rédiger le rapport final. J'ai utilisé pour cela **Kali Linux**, l'outil de prise de notes **CherryTree** et l'outil de reconnaissance **SpiderFoot**.

2. Préparation de l'environnement

Avant de commencer le TP, j'ai **créé une machine virtuelle Windows 7 SP1** en suivant le tutoriel du TP précédent (TP2.2 – « les machines nécessaires »). Cette machine joue le rôle de **victime**, tandis que la machine **Kali Linux** joue le rôle de l'**attaquant**.

B3 TP2.2 : Test d'intrusion : les machines nécessaires

On a vu la méthodologie que l'on va utiliser pour effectuer nos tests d'intrusion.
Pour faire cela, on a besoin de quelques machines virtuelles :

- L'**attaquant** : kali Linux,
- La **victime** : Windows Seven SP1 Ultimate

Ex1 : préparer ces machines et vérifier qu'elles sont dans le même réseau

Figure 1 – Rappel du TP2.2 : les machines nécessaires (Kali = attaquant, Windows Seven SP1 Ultimate = victime)

Comme demandé dans le tutoriel, j'ai ensuite vérifié que les deux machines virtuelles se trouvent bien **dans le même réseau**, condition indispensable pour pouvoir les faire communiquer et lancer les scans.

3. Les deux types de reconnaissance

Dans un test d'intrusion, la reconnaissance se divise en deux parties : la **partie passive** et la **partie active**. J'ai retenu les différences suivantes :

	Reconnaissance passive	Reconnaissance active
Principe	Récolte d'informations sans interaction avec la cible : on n'envoie rien depuis notre machine ou notre adresse IP.	Récolte d'informations avec interaction avec la cible (fait partie du scanning) : on envoie des paquets de test au serveur.
Sources / outils	Informations publiques : moteurs de recherche, réseaux sociaux, forums, bases de données publiques de comptes piratés.	Outils comme nmap, nessus et autres scanners de serveurs web.

	Reconnaissance passive	Reconnaissance active
Informations obtenues	Emails, mots de passe, noms d'utilisateurs, technologies utilisées par l'entreprise (version de PHP, Django, type de base de données...).	Protocoles et services utilisés, ports ouverts / fermés / filtrés.
Avantage	Potentiel illimité : toute information trouvée en ligne peut servir à la phase d'exploitation.	Donne beaucoup plus d'informations.
Inconvénient	Résultats limités.	On peut être bloqué par un pare-feu ou par notre adresse IP si on envoie trop de paquets suspects.

4. La documentation avec CherryTree

Pendant un test d'intrusion, il faut **documenter pas à pas** tout ce que l'on fait : les commandes exécutées, les outils utilisés, les ressources utilisées et les résultats obtenus. Plus la documentation est organisée, plus le rapport final sera productif. J'ai utilisé **CherryTree**, préinstallé sur Kali Linux.

4.1 Lancement de CherryTree

J'ai démarré la machine Kali, recherché « CherryTree » dans le menu des applications puis lancé le logiciel.

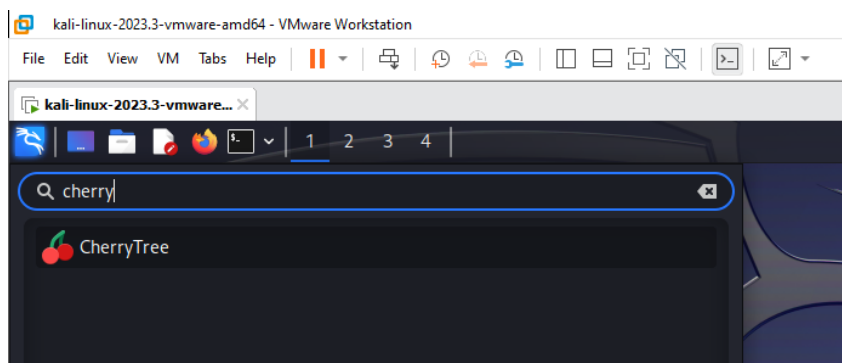


Figure 2 – Recherche de CherryTree dans Kali Linux

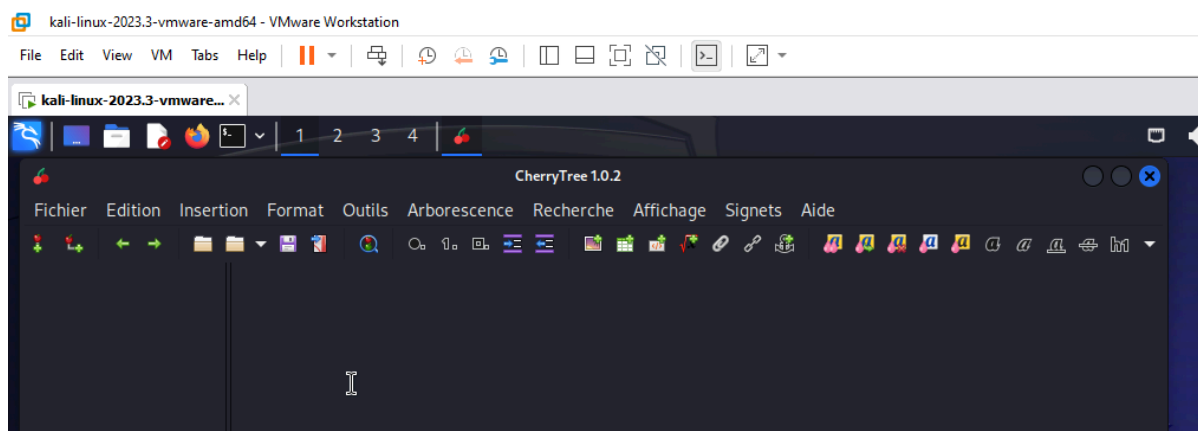


Figure 3 – CherryTree 1.0.2 est lancé

4.2 Création de l'arborescence

J'ai d'abord créé un nœud **Reconnaissance**, dans lequel on peut coller les résultats d'un scan nmap, puis d'un outil comme nikto, en les séparant.

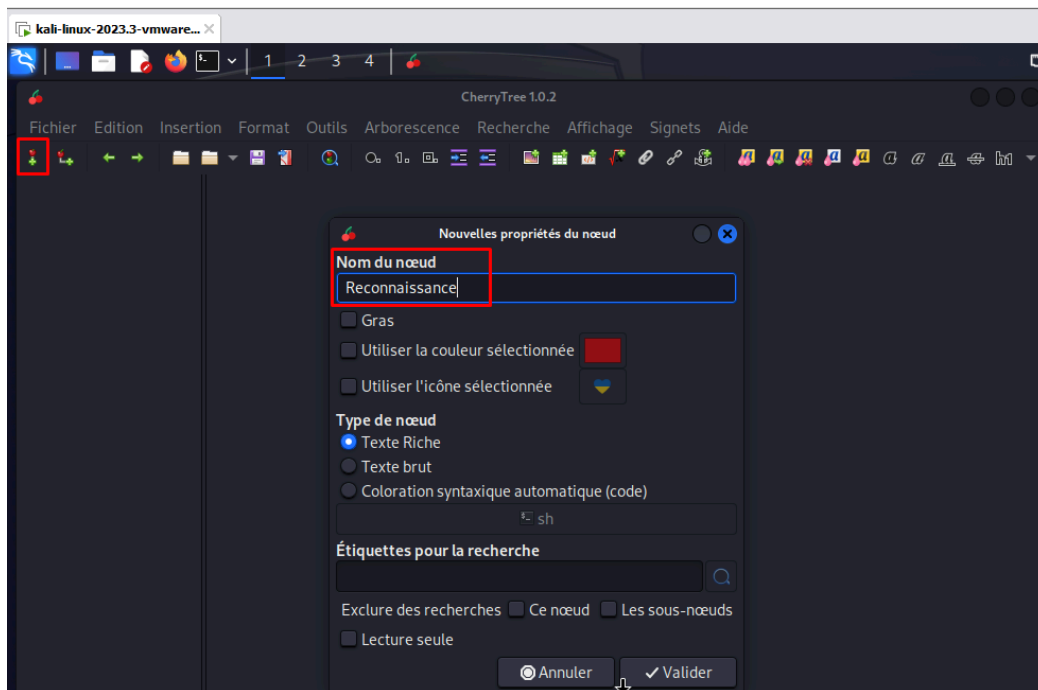


Figure 4 – Création du nœud « Reconnaissance »

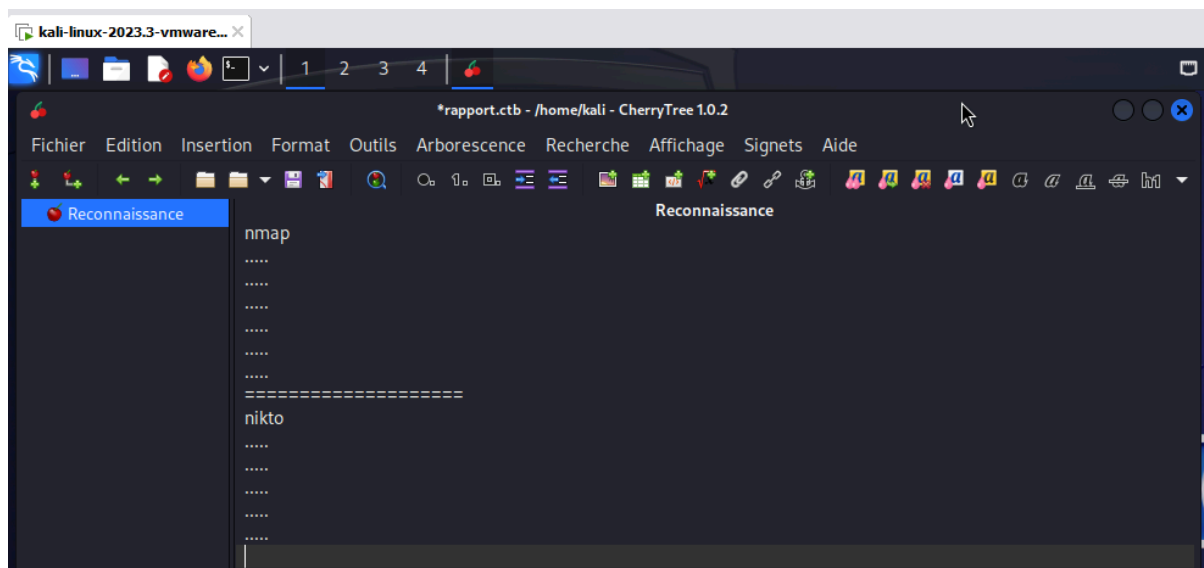


Figure 5 – Le nœud Reconnaissance contenant les résultats de nmap et nikto

J'ai ensuite créé la section **Exploitation**.

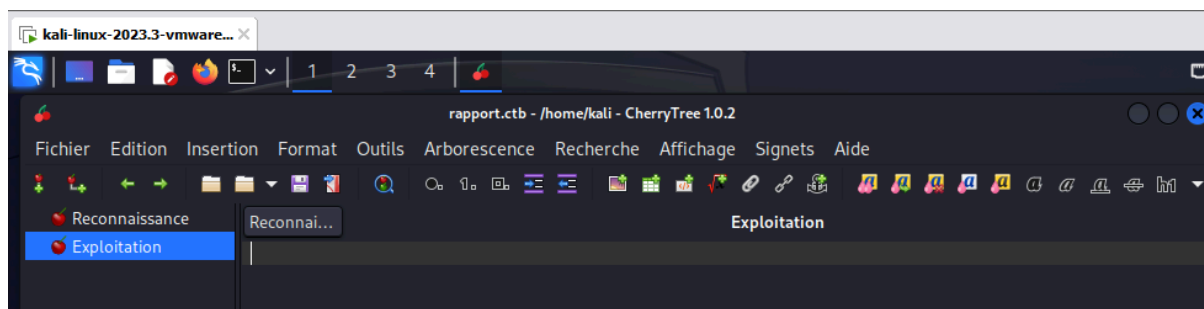


Figure 6 – Création de la section « Exploitation »

Puis j'ai créé les sous-nœuds « Recon passive » et « Recon active » et je les ai déplacés sous « Reconnaissance » pour obtenir la bonne arborescence.

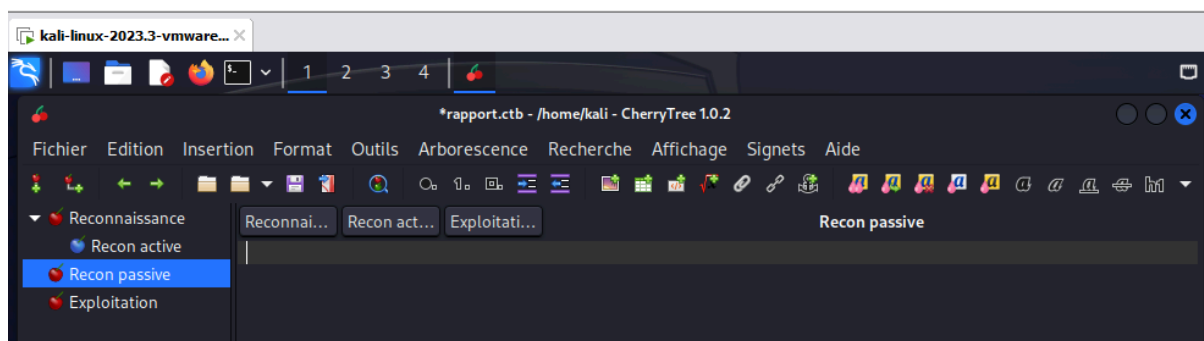


Figure 7 – Création des nœuds de reconnaissance passive et active

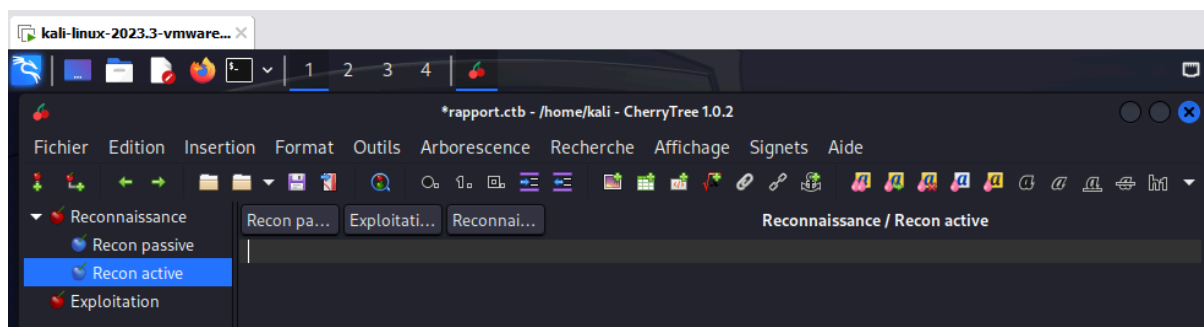


Figure 8 – Déplacement de « Recon passive » sous « Reconnaissance »

Enfin, j'ai finalisé l'arborescence en ajoutant les nœuds **Metasploit** et **MsfVenom** sous « Exploitation ».

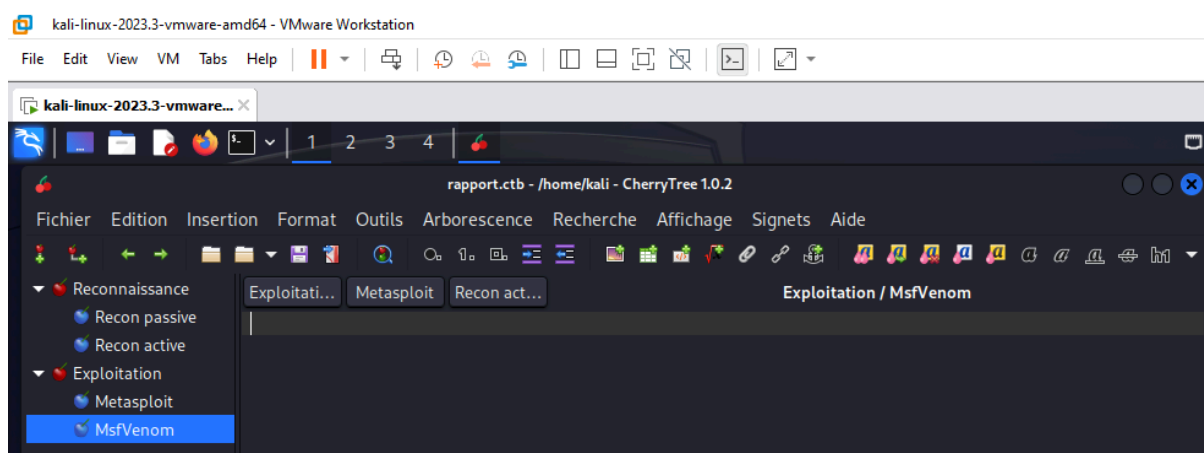


Figure 9 – Arborescence finale dans CherryTree

À la fin du test d'intrusion, grâce à CherryTree, je retrouverai toutes les informations de façon très organisée, ce qui facilitera la rédaction du rapport final.

5. Les outils de reconnaissance de Kali Linux

Dans le menu de Kali, la catégorie **01 – Récupération d'informations** regroupe de nombreux outils permettant de faire du scanning passif et actif sur un réseau ou un système cible.

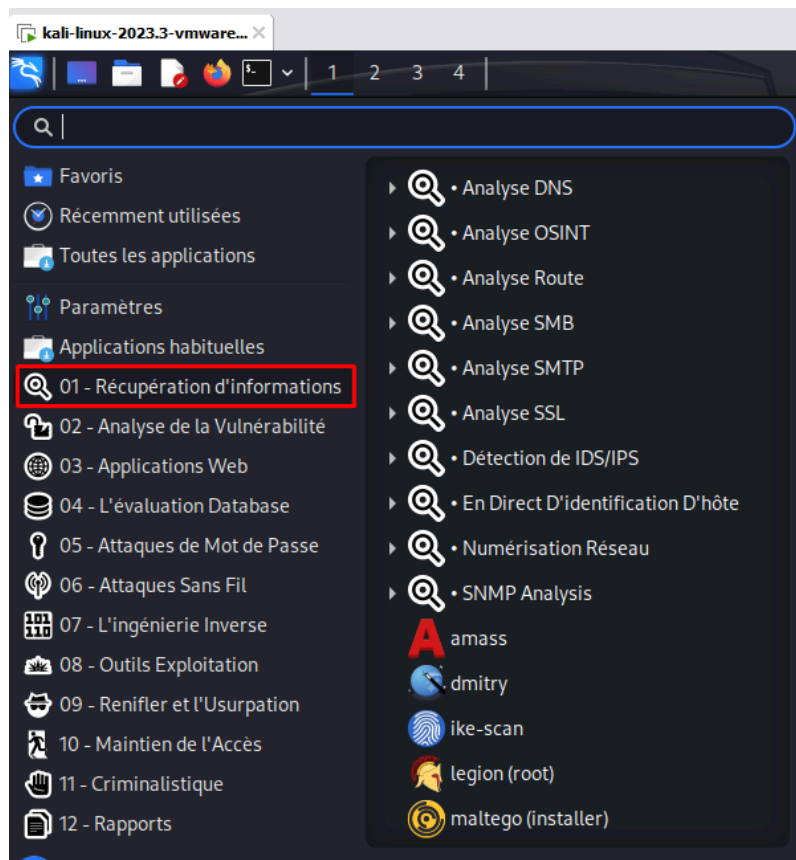
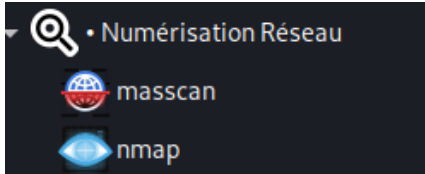
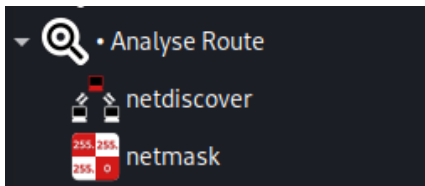
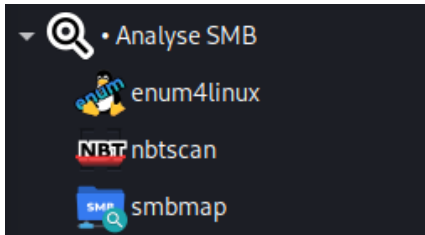
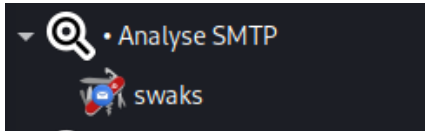
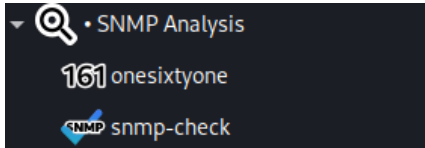
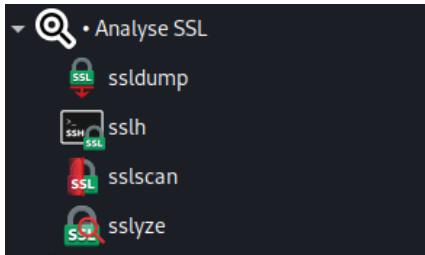


Figure 10 – Menu « 01 – Récupération d'informations » de Kali Linux

J'ai parcouru chacune des sections du menu :

Section	Rôle	Outils (capture)
Analyse DNS	Le DNS (Domain Name System) traduit un nom de domaine en adresse IP. Ces outils permettent de faire une reconnaissance spécifique sur ce protocole.	Analyse DNS dnsenum dnsrecon fierce
Détection de IDS/IPS	Un IDS détecte les attaques sur un réseau ou un système, un IPS les prévient. Ces outils permettent de voir si un pare-feu ou un IDS/IPS protège la cible ; wafw00f teste si la cible est protégée par un pare-feu.	Détection de IDS/IPS lbd wafw00f

Section	Rôle	Outils (capture)
En direct d'identification d'hôte	Détecte si la cible (système, serveur) est active ou non.	 - En Direct D'identification D'hôte - arping - fping - hping3 - masscan - netcat - thcping6
Numérisation réseau	Utilisés pour le scanning des systèmes d'exploitation (nmap, masscan).	 - Numérisation Réseau - masscan - nmap
Analyse OSINT	Open Source INTelligence : récoltent automatiquement, de façon passive et active, le maximum d'informations disponibles sur Internet. Le résultat est enregistré dans la base de données de SpiderFoot.	 - Analyse OSINT - maltego (installer) - spiderfoot - spiderfoot-cli - theharvester
Analyse Route	Détectent les routes d'un réseau.	 - Analyse Route - netdiscover - netmask
Analyse SMB	SMB est un protocole de l'environnement Microsoft dont les versions sont vulnérables : ces outils permettent de l'analyser et de l'exploiter.	 - Analyse SMB - enum4linux - nbtscan - smbmap
Analyse SMTP	SMTP gère l'envoi et la réception des emails. L'outil aide à scanner et à tester ce protocole.	 - Analyse SMTP - swaks
Analyse SNMP	Détecte si le protocole SNMP existe et donne des informations dessus (versions...).	 - SNMP Analysis - onesixtyone - snmp-check

Section	Rôle	Outils (capture)
Analyse SSL	Utilisés surtout pour les serveurs web : détectent la version de SSL utilisée et aident à formuler des recommandations (par exemple mettre à jour un SSL trop ancien).	

Plus on a d'informations sur une cible, plus on a d'options d'exploitation et de recommandations à donner au client.

6. Test du ping sur la machine Windows (Ex5)

Depuis Kali, en mode console, j'ai pingué la machine Windows 7 SP1 que j'avais créée.

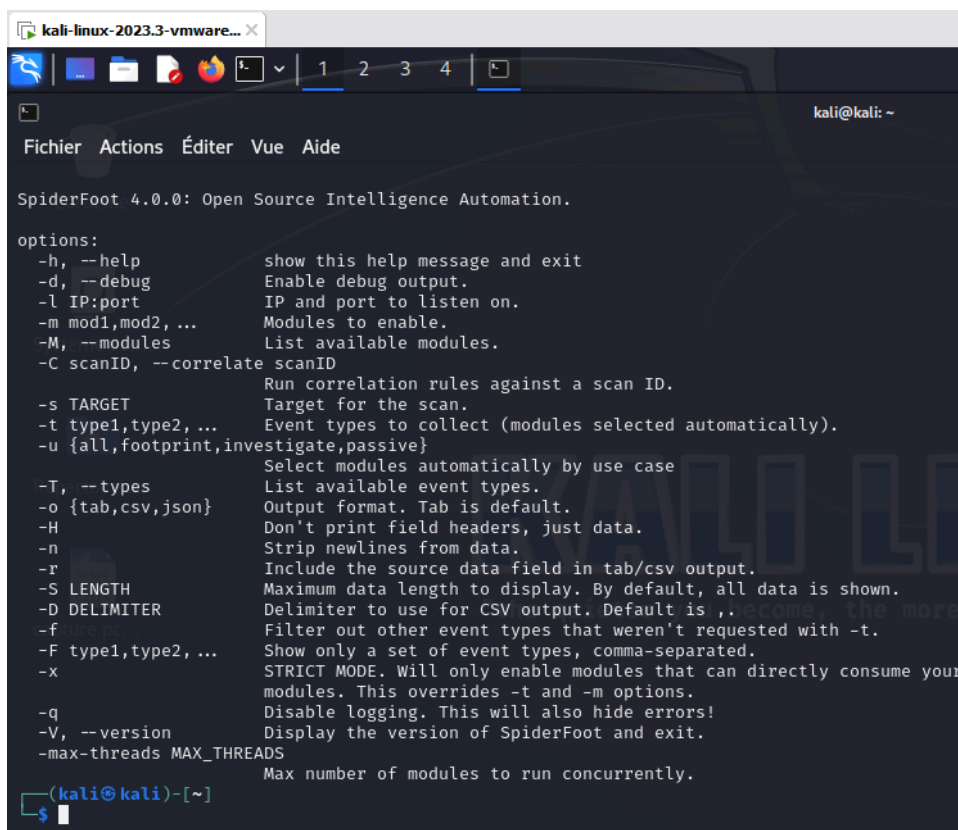
Les machines Windows sont prévues pour ne pas répondre au ping, car c'est un élément utilisé par les hackers éthiques et les testeurs d'intrusion pour détecter services, ports et protocoles : c'est un moyen de protection de Microsoft. Si un ping reste sans réponse, cela ne signifie donc pas que la machine est éteinte.

7. Reconnaissance avec SpiderFoot

SpiderFoot est un outil, installé par défaut sur Kali Linux, qui permet de faire une reconnaissance passive et active sur une cible.

7.1 Lancement de SpiderFoot

J'ai démarré SpiderFoot en mode console (aide de l'outil affichée ci-dessous) puis j'ai élevé mes privilèges avec la commande sudo su.



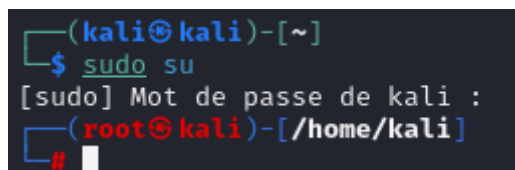
```
kali-linux-2023.3-vmware...
Fichier Actions Éditer Vue Aide

SpiderFoot 4.0.0: Open Source Intelligence Automation.

options:
-h, --help            show this help message and exit
-d, --debug           Enable debug output.
-l IP:port            IP and port to listen on.
-m mod1,mod2, ...    Modules to enable.
-M, --modules         List available modules.
-C scanID, --correlate scanID
                    Run correlation rules against a scan ID.
-s TARGET             Target for the scan.
-t type1,type2, ...   Event types to collect (modules selected automatically).
-u {all,footprint,investigate,passive}
                    Select modules automatically by use case
-T, --types           List available event types.
-o {tab,csv,json}     Output format. Tab is default.
-H                   Don't print field headers, just data.
-n                   Strip newlines from data.
-r                   Include the source data field in tab/csv output.
-S LENGTH             Maximum data length to display. By default, all data is shown.
-D DELIMITER          Delimiter to use for CSV output. Default is ','.
-f type1,type2, ...   Filter out other event types that weren't requested with -t.
-x                   Show only a set of event types, comma-separated.
                    STRICT MODE. Will only enable modules that can directly consume your
                    modules. This overrides -t and -m options.
-q                   Disable logging. This will also hide errors!
-V, --version         Display the version of SpiderFoot and exit.
-max-threads MAX_THREADS
                    Max number of modules to run concurrently.

(kali@kali)-[~]
$
```

Figure 11 – Aide de SpiderFoot 4.0.0 dans le terminal

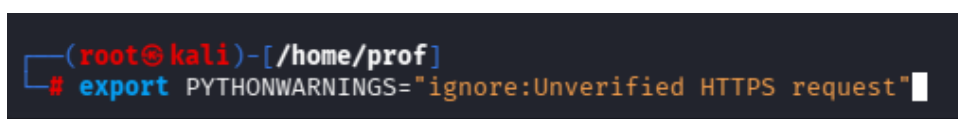


```
(kali@kali)-[~]
$ sudo su
[sudo] Mot de passe de kali :
(root@kali)-[/home/kali]
#
```

Figure 12 – Élévation des privilèges (sudo su)

Signification de l'option -l : elle indique l'adresse IP et le port sur lesquels SpiderFoot doit écouter (« IP and port to listen on »). SpiderFoot possède en effet une interface sur un serveur web : il faut donc lancer le serveur web local de Kali Linux, et pour cela connaître l'adresse IP de la machine Kali.

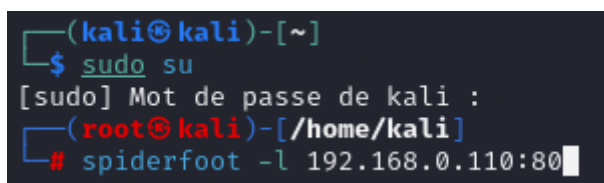
J'ai d'abord saisi la commande suivante, qui sert à ignorer la vérification SSL :



```
(root@kali)-[/home/prof]
# export PYTHONWARNINGS=ignore:Unverified HTTPS request
```

Figure 13 – Commande pour ignorer la vérification SSL

J'ai ensuite lancé le serveur web sur le port 80 avec l'adresse IP de ma machine Kali (ici 192.168.0.110) :



```
(kali@kali)-[~]
$ sudo su
[sudo] Mot de passe de kali :
(root@kali)-[/home/kali]
# spiderfoot -l 192.168.0.110:80
```

Figure 14 – Commande spiderfoot -l <adresse IP Kali>:80

```
(kali㉿kali)-[~]
$ sudo su
[sudo] Mot de passe de kali :
(kali㉿kali)-[/home/kali]
# spiderfoot -l 192.168.0.110:80
2024-03-08 10:48:43,085 [INFO] sf : Starting web server at 192.168.0.110:80 ...

*****
2024-03-08 10:48:43,128 [WARNING] sf :
*****
Warning: passwd file contains no passwords. Authentication disabled.
Please consider adding authentication to protect this instance!
Refer to https://www.spiderfoot.net/documentation/#security.
*****

Use SpiderFoot by starting your web browser of choice and
browse to http://192.168.0.110:80/
*****
```

Figure 15 – Démarrage du serveur web SpiderFoot

Le terminal fonctionne alors en arrière-plan. J’ai ouvert le navigateur à l’adresse indiquée : l’interface de SpiderFoot s’affiche.

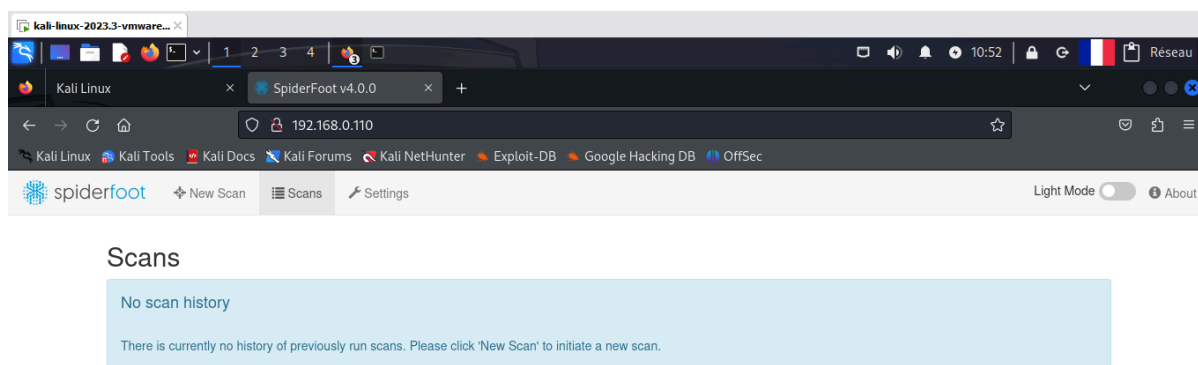


Figure 16 – Interface web de SpiderFoot dans le navigateur (aucun scan pour l’instant)

7.2 Paramétrage d’un scan

J’ai lancé un scan en cliquant sur **New Scan**. Le champ **Scan name** contient le nom du scan (par exemple « Test intrusion NomClient ») et **Scan target** contient un nom de domaine, une adresse IP ou l’adresse d’un réseau (par exemple 192.168.0.0/24).

SpiderFoot New Scan Scans Settings Light Mode About

New Scan

Scan Name
The name of this scan.

Scan Target
The target of your scan.

ⓘ Your scan target may be one of the following. SpiderFoot will automatically detect the target type based on the format of your input.

Domain Name: e.g. `example.com`
 IPv4 Address: e.g. `1.2.3.4`
 IPv6 Address: e.g. `2606:4700:4700::1111`
 Hostname/Sub-domain: e.g. `abc.example.com`
 Subnet: e.g. `1.2.3.0/24`
 Bitcoin Address: e.g. `1HesYJSP1QqcyPEjnQ9vzBL1wujuNGe7R`
 E-mail address: e.g. `bob@example.com`
 Phone Number: e.g. `+12345678901` (E.164 format)
 Human Name: e.g. `"John Smith"` (must be in quotes)
 Username: e.g. `"jsmith2000"` (must be in quotes)
 Network ASN: e.g. `1234`

By Use Case By Required Data By Module

☒ **All** **Get anything and everything about the target.**
 All SpiderFoot modules will be enabled (slow) but every possible piece of information about the target will be obtained and analysed.

☐ **Footprint** **Understand what information this target exposes to the Internet.**
 Gain an understanding about the target's network perimeter, associated identities and other information that is obtained through a lot of web crawling and search engine use.

☐ **Investigate** **Best for when you suspect the target to be malicious but need more information.**
 Some basic footprinting will be performed in addition to querying of blacklists and other sources that may have information about your target's maliciousness.

♥ Join the SpiderFoot community Discord!

Figure 17 – Page « New Scan » de SpiderFoot

Un scan peut être très long selon la taille du réseau. Pour alléger la recherche lors d'une attaque sur un réseau local, on peut utiliser le cas d'usage **Investigate** :

By Use Case By Required Data By Module

☒ **All** **Get anything and everything about the target.**
 All SpiderFoot modules will be enabled (slow) but every possible piece of information about the target will be obtained and analysed.

☐ **Footprint** **Understand what information this target exposes to the Internet.**
 Gain an understanding about the target's network perimeter, associated identities and other information that is obtained through a lot of web crawling and search engine use.

☐ **Investigate** **Best for when you suspect the target to be malicious but need more information.**
 Some basic footprinting will be performed in addition to querying of blacklists and other sources that may have information about your target's maliciousness.

☐ **Passive** **When you don't want the target to even suspect they are being investigated.**
 As much information will be gathered without touching the target or their affiliates, therefore only modules that do not touch the target will be enabled.

Figure 18 – Choix du cas d'usage « Investigate »

On peut aussi sélectionner peu de modules (onglet **By Module**, puis **De-Select All**) :

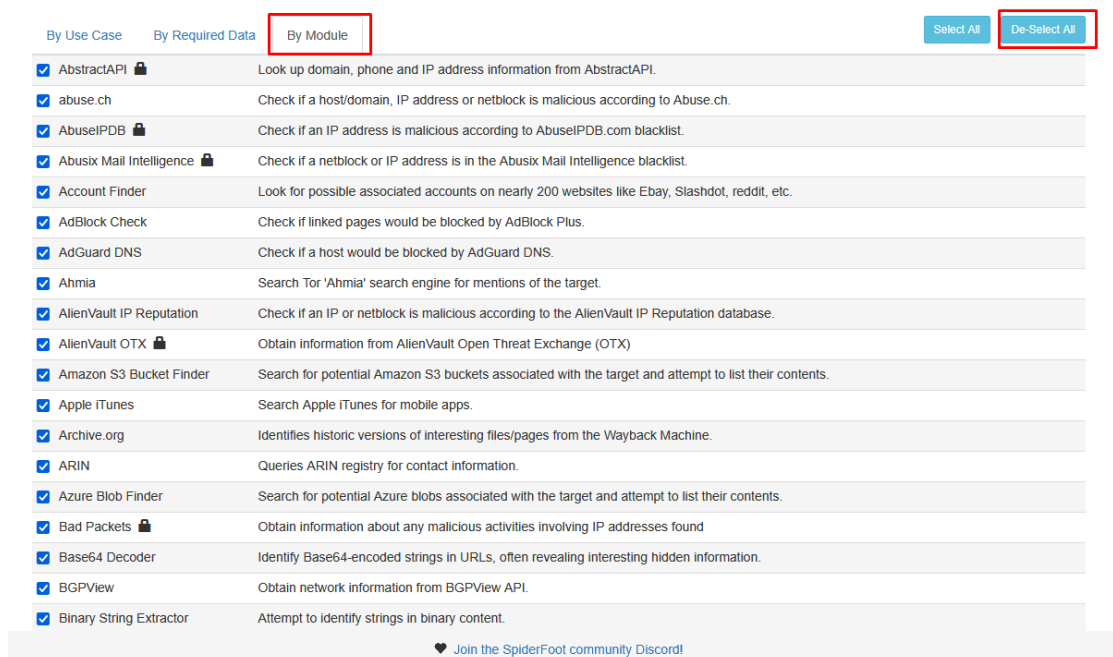


Figure 19 – Onglet « By Module » : désélection de tous les modules

J'ai sélectionné seulement les modules suivants :

- **Port Scanner – TCP** : recherche les ports TCP couramment ouverts sur les systèmes exposés à Internet ;

☒ Port Scanner - TCP Scans for commonly open TCP ports on Internet-facing systems.

Figure 20 – Module Port Scanner – TCP

- **Web Server Identifier** : récupère les bannières des serveurs web pour identifier leur version ;

☒ Web Server Identifier Obtain web server banners to identify versions of web servers being used.

Figure 21 – Module Web Server Identifier

- **DNS Resolver** : résout les hôtes et adresses IP identifiés ;

☒ DNS Resolver Resolves hosts and IP addresses identified, also extracted from raw content.

Figure 22 – Module DNS Resolver

- **Tool – nbtscan** : recherche les serveurs de noms NETBIOS ouverts sur le réseau de la cible ;

☒ Tool - nbtscan Scans for open NETBIOS nameservers on your target's network.

Figure 23 – Module Tool – nbtscan

- **Tool – Nmap** : identifie quel système d'exploitation peut être utilisé ;

☒ Tool - Nmap Identify what Operating System might be used.

Figure 24 – Module Tool – Nmap

- **DNS Raw Records** : récupère les enregistrements DNS bruts (MX, TXT, etc.).

☒ DNS Raw Records Retrieves raw DNS records such as MX, TXT and others.

Figure 25 – Module DNS Raw Records

7.3 Exécution et résultats du scan

Une fois le scan lancé, le terminal fonctionne en arrière-plan et affiche les requêtes effectuées, tandis que les résultats apparaissent dans le navigateur.

```
root@kali: /home/kali
Fichier Actions Éditer Vue Aide
.0) Gecko/20100101 Firefox/62.0, timeout=5, cookies=None)
2024-03-08 11:28:42,781 [INFO] sflib : Fetching (GET): https://api.mnemonic.no/pdns/v3/192.168.0.4?limit=500&offset=0 (proxy=None, user-agent=Gecko/20100101 Firefox/62.0, timeout=30, cookies=None)
2024-03-08 11:28:43,017 [INFO] sflib : Fetched https://api.flickr.com/services/rest?sort=relevance&parse_tags=1&content_type=7&extras=desc:alias%2Crealname&hermes=16hermesClient=16reqId=6nojsoncallback=16viewerNSID=6method=flickr.photos.search&csrf=6lang=en-US&per_page=100&page=1 (128 bytes in 0.7848341464996338s)
2024-03-08 11:28:43,186 [INFO] sflib : Fetched https://threatfox-api.abuse.ch/api/v1/ (88 bytes in 0.6060140132904053s)
2024-03-08 11:28:44,023 [INFO] sfp_flickr : Parsing page 1 of 0
2024-03-08 11:28:44,023 [ERROR] sfp_fullcontact : You enabled sfp_fullcontact but did not set an API key!
2024-03-08 11:28:44,024 [INFO] sflib : Fetching (GET): https://sonar.omnisint.io/subdomains/btssiozap.com?page=0 (proxy=None, user-agent=Gecko/20100101 Firefox/62.0, timeout=30, cookies=None)
2024-03-08 11:28:44,191 [INFO] sflib : Fetching (GET): https://en.wikipedia.org/w/api.php?action=feedcontributions&user=XXX (proxy=None, user-agent=Gecko/20100101 Firefox/62.0, timeout=5, cookies=None)
2024-03-08 11:28:45,108 [INFO] sflib : Fetched https://en.wikipedia.org/w/api.php?action=feedcontributions&user=XXX (431 bytes in 0.9171011011011011s)
2024-03-08 11:28:46,059 [INFO] sflib : Fetched https://btssiozapcomspace.nyc3.digitaloceanspaces.com (250 bytes in 5.733612060546875s)
2024-03-08 11:28:46,376 [INFO] sfp_digitaloceanspace : Spawning thread to check bucket: https://btssiozapcomdata.nyc3.digitaloceanspaces.com
2024-03-08 11:28:46,380 [INFO] sfp_digitaloceanspace : Spawning thread to check bucket: https://btssiozapcomprod.nyc3.digitaloceanspaces.com
2024-03-08 11:28:46,383 [INFO] sfp_digitaloceanspace : Spawning thread to check bucket: https://btssiozapcomstaging.nyc3.digitaloceanspaces.com
2024-03-08 11:28:47,072 [INFO] sflib : Fetched https://btssiozapcomprod.nyc3.digitaloceanspaces.com (249 bytes in 0.690941572189331s)
2024-03-08 11:28:47,091 [INFO] sflib : Fetched https://btssiozapcomstaging.nyc3.digitaloceanspaces.com (252 bytes in 0.7070329189300537s)
2024-03-08 11:28:47,101 [INFO] sflib : Fetched https://btssiozapcomdata.nyc3.digitaloceanspaces.com (249 bytes in 0.7226169109344482s)
2024-03-08 11:28:47,407 [INFO] sfp_digitaloceanspace : Spawning thread to check bucket: https://btssiozapcomproduction.nyc3.digitaloceanspaces.com
2024-03-08 11:28:47,411 [INFO] sfp_digitaloceanspace : Spawning thread to check bucket: https://btssiozapcomstage.nyc3.digitaloceanspaces.com
2024-03-08 11:28:47,415 [INFO] sfp_digitaloceanspace : Spawning thread to check bucket: https://btssiozapcomapp.nyc3.digitaloceanspaces.com
2024-03-08 11:28:48,151 [INFO] sflib : Fetched https://btssiozapcomproduction.nyc3.digitaloceanspaces.com (255 bytes in 0.7417664527893066s)
2024-03-08 11:28:48,222 [INFO] sflib : Fetched https://btssiozapcomapp.nyc3.digitaloceanspaces.com (248 bytes in 0.8066542148590088s)
2024-03-08 11:28:48,379 [INFO] sflib : Fetched https://btssiozapcomstage.nyc3.digitaloceanspaces.com (250 bytes in 0.9662487506866455s)
2024-03-08 11:28:48,668 [INFO] sflib : Fetching (GET): https://freeapi.robtex.com/ipquery/192.168.0.44 (proxy=None, user-agent=SpiderFoot, timeout=5, cookies=None)
2024-03-08 11:28:48,672 [INFO] sfp_digitaloceanspace : Spawning thread to check bucket: https://btssiozapcommedia.nyc3.digitaloceanspaces.com
2024-03-08 11:28:48,673 [INFO] sfp_digitaloceanspace : Spawning thread to check bucket: https://btssiozapcomdevelopment.nyc3.digitaloceanspaces.com
2024-03-08 11:28:48,677 [INFO] sfp_digitaloceanspace : Spawning thread to check bucket: https://btssiozapcom-test.nyc3.digitaloceanspaces.com
```

Figure 26 – Le terminal en arrière-plan pendant le scan

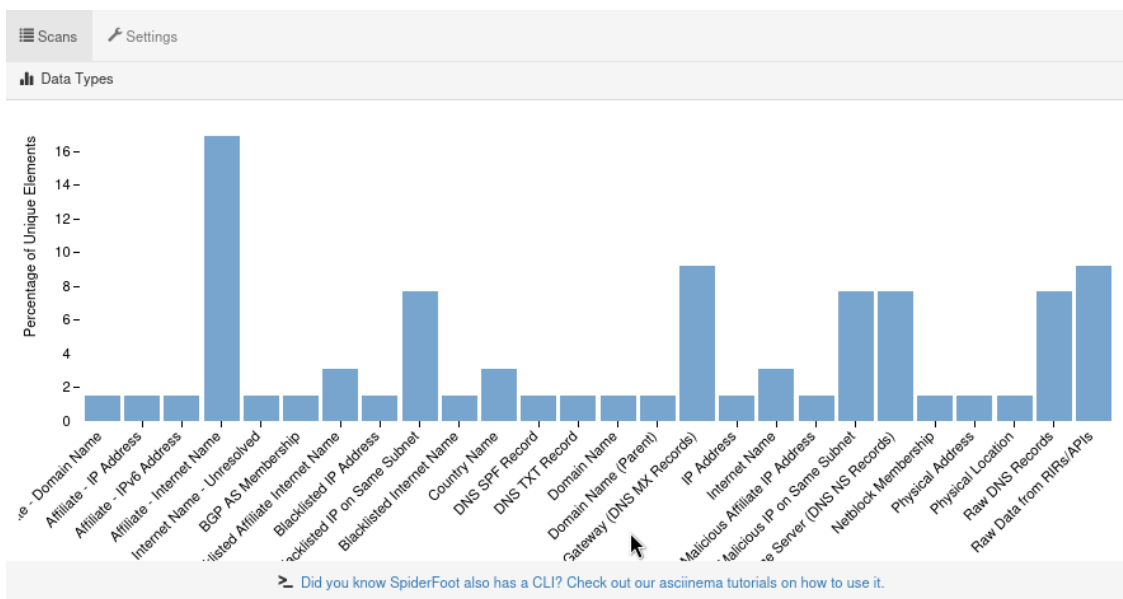


Figure 27 – Résultats du scan dans le navigateur (types de données)

En effectuant un scan avec l'option **All**, on obtient beaucoup plus d'informations :

By Use Case By Required Data By Module

☒ All Get anything and everything about the target.

All SpiderFoot modules will be enabled (slow) but every possible piece of information about the target will be obtained and analysed.

Figure 28 – Cas d'usage « All »

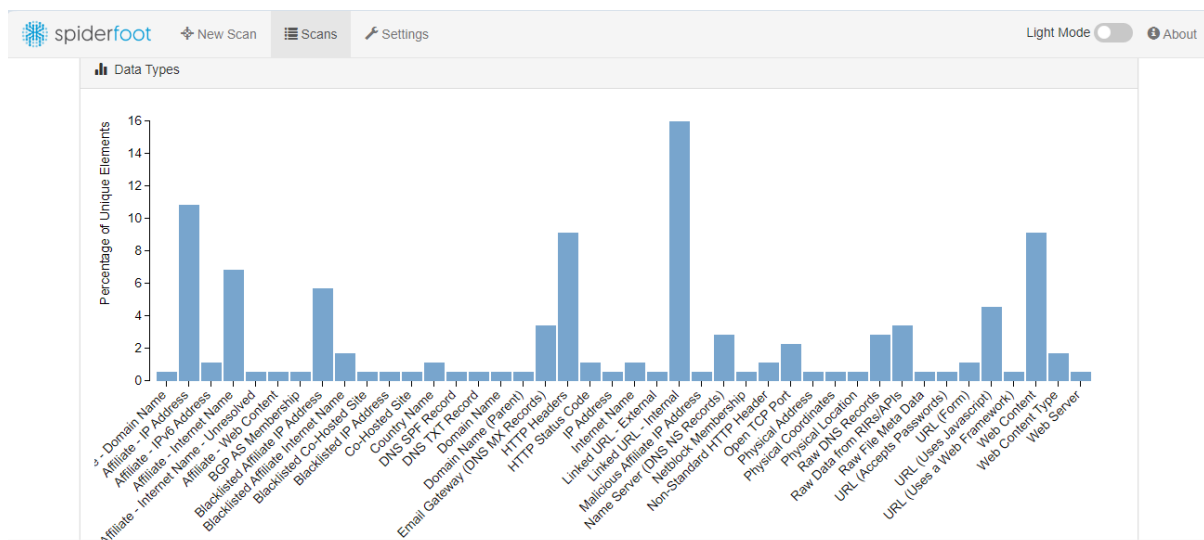


Figure 29 – Résultats d'un scan avec l'option « All »

L'onglet **By Required Data** permet de voir la liste des informations recherchées. Certaines sont récupérables en mode passif, d'autres seulement en mode actif.

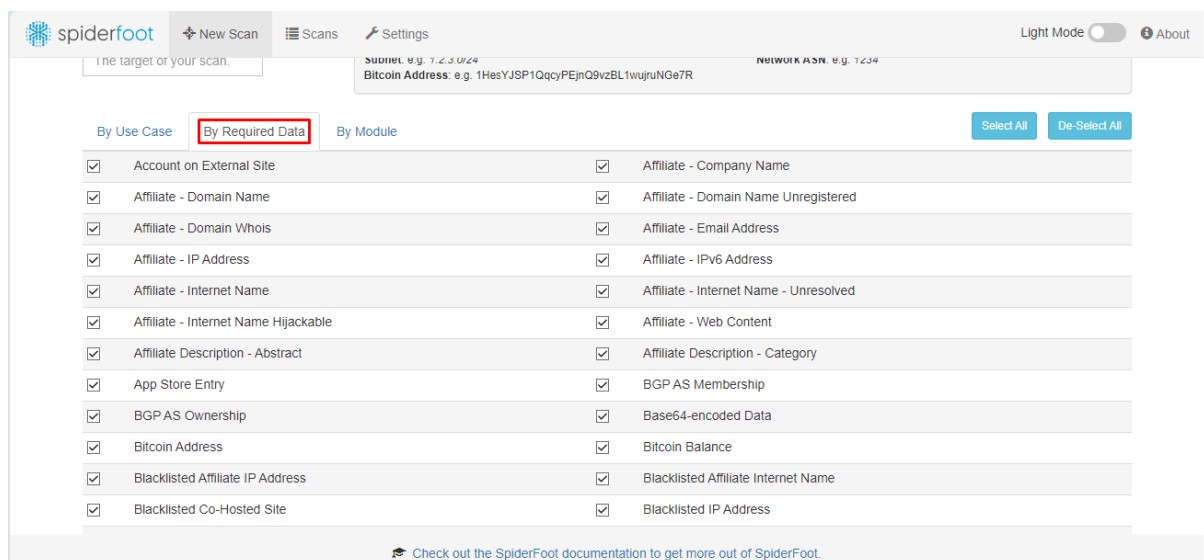


Figure 30 – Onglet « By Required Data »

L'onglet **By Module** contient les modules utilisés par SpiderFoot. Tous ces outils tiers (bases de données publiques) permettent de récupérer un maximum d'informations. Voici un extrait de la liste :

By Use Case	By Required Data	By Module
☒	☐	☒
☒ AbstractAPI 		Look up domain, phone and IP address information from AbstractAPI.
☒ abuse.ch		Check if a host/domain, IP address or netblock is malicious according to Abuse.ch.
☒ AbuseIPDB 		Check if an IP address is malicious according to AbuseIPDB.com blacklist.
☒ Abusix Mail Intelligence 		Check if a netblock or IP address is in the Abusix Mail Intelligence blacklist.
☒ Account Finder		Look for possible associated accounts on nearly 200 websites like Ebay, Slashdot, reddit, etc.
☒ AdBlock Check		Check if linked pages would be blocked by AdBlock Plus.
☒ AdGuard DNS		Check if a host would be blocked by AdGuard DNS.
☒ Ahmia		Search Tor 'Ahmia' search engine for mentions of the target.
☒ AlienVault IP Reputation		Check if an IP or netblock is malicious according to the AlienVault IP Reputation database.
☒ AlienVault OTX 		Obtain information from AlienVault Open Threat Exchange (OTX)
☒ Amazon S3 Bucket Finder		Search for potential Amazon S3 buckets associated with the target and attempt to list their contents.
☒ Apple iTunes		Search Apple iTunes for mobile apps.

Figure 31 – Onglet « By Module » : début de la liste des modules

☒	Gravatar	Retrieve user information from Gravatar API.
☒	Grayhat Warfare 	Find bucket names matching the keyword extracted from a domain from Grayhat API.
☒	Greensnow	Check if a netblock or IP address is malicious according to greensnow.co.
☒	grep.app	Search grep.app API for links and emails related to the specified domain.
☒	GreyNoise 	Obtain IP enrichment data from GreyNoise
☒	HackerOne (Unofficial)	Check external vulnerability scanning/reporting service h1.nobbd.de to see if the target is listed.
☒	HackerTarget	Search HackerTarget.com for hosts sharing the same IP.
☒	Hash Extractor	Identify MD5 and SHA hashes in web content, files and more.
☒	HavelBeenPwned 	Check HavelBeenPwned.com for hacked e-mail addresses identified in breaches.
☒	Host.io 	Obtain information about domain names from host.io.
☒	Hosting Provider Identifier	Find out if any IP addresses identified fall within known 3rd party hosting ranges, e.g. Amazon, Azure, etc.
☒	Human Name Extractor	Attempt to identify human names in fetched content.

Figure 32 – Extrait de la liste des modules (dont HackerOne)

7.4 Exercice 6 : le site HackerOne

Parmi les modules figure **HackerOne (Unofficial)**, qui vérifie sur le service h1.nobbd.de si la cible est listée dans les rapports de vulnérabilités. **HackerOne** est une plateforme de **bug bounty** : elle met en relation des entreprises et des chercheurs en sécurité (hackers éthiques) qui signalent les failles qu'ils découvrent, en échange de récompenses. Ce site est donc une source d'information utile pour savoir si une cible a déjà fait l'objet de vulnérabilités déclarées.

7.5 Suivi et résultats

Les résultats se voient dans la page principale de SpiderFoot. Au début du scan, seuls 3 éléments avaient été trouvés ; au bout d'une heure, on en comptait 362.

Scans

▼ Filter: None

↺

■

↻

📄

🗑

☐	Name	Target	Started	Finished	Status	Elements	Correlations	Action
☐	test scan	btssiogap.com	2024-03-09 09:45:36	Not yet	RUNNING	3	0000	⌵⌶

⏮

⏪

⏩

⏭

10

▼

1

▼

Scans 1 - 1 / 1 (1)

Figure 33 – Scans : début du scan (3 éléments)

Scans

▼ Filter: None

↺

■

↺

↓

🗑

☐	Name	Target	Started	Finished	Status	Elements	Correlations	Action
☐	test scan	btssiogap.com	2024-03-09 09:45:36	Not yet	RUNNING	362	0000	⌵
⏮⏪⏩⏭ 10 1 Scans 1 - 1 / 1 (1)								

Figure 34 – Scans : au bout d'une heure (362 éléments)

On peut afficher le graphe des informations trouvées, ainsi que la liste détaillée (onglet **Browse**) :

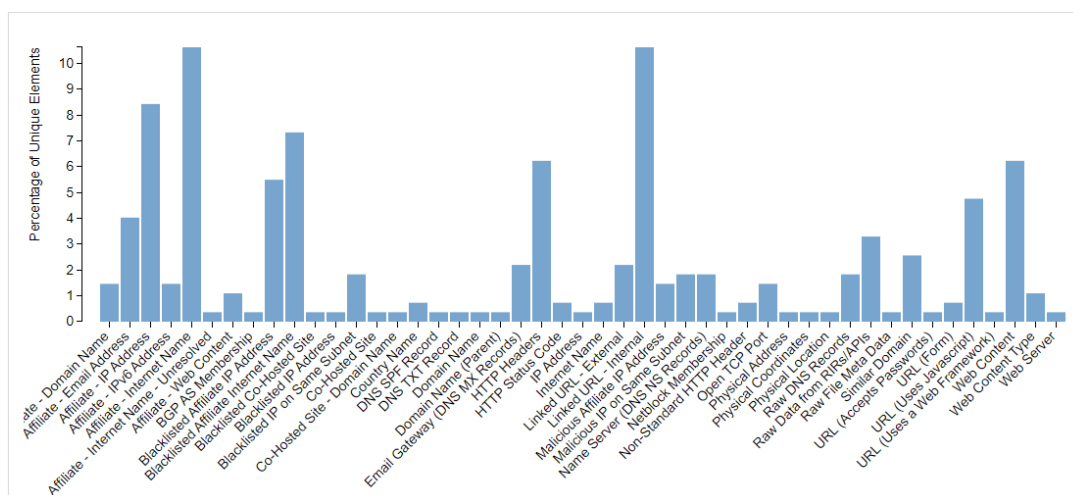


Figure 35 – Graphe des informations trouvées

Summary

Correlations

Browse

Graph

Scan Settings

Log

↺

↴

Search...

Type	Unique Data Elements	Total Data Elements	Last Data Element
Affiliate - Domain Name	4	14	2024-03-09 10:09:35
Affiliate - Email Address	11	11	2024-03-09 10:08:58
Affiliate - IP Address	23	26	2024-03-09 10:09:36
Affiliate - IPv6 Address	4	4	2024-03-09 10:09:36
Affiliate - Internet Name	29	41	2024-03-09 10:10:14
Affiliate - Internet Name - Unresolved	1	1	2024-03-09 09:46:48
Affiliate - Web Content	3	3	2024-03-09 10:07:00
BGP AS Membership	1	2	2024-03-09 09:55:56
Blacklisted Affiliate IP Address	15	15	2024-03-09 10:06:11
Blacklisted Affiliate Internet Name	20	20	2024-03-09 10:08:42
Blacklisted Co-Hosted Site	1	1	2024-03-09 10:01:13
Blacklisted IP Address	1	1	2024-03-09 09:54:55
Blacklisted IP on Same Subnet	5	5	2024-03-09 10:06:23

Figure 36 – Liste des informations trouvées (onglet Browse)

Toutes ces informations pourront être incluses dans le **rapport** final du test d'intrusion.

8. Exercice 7 : scan d'un serveur web local

Rappel de sécurité : un scan ne doit jamais être effectué sur une cible qui ne m'appartient pas, car il peut la faire planter. Je ne travaille donc que sur mon propre site, serveur ou réseau.

9. Conclusion

Ce TP m'a permis de comprendre la différence entre reconnaissance passive et active, de mettre en place une documentation organisée avec CherryTree et de prendre en main SpiderFoot pour récolter automatiquement un grand nombre d'informations sur une cible. Ces informations seront réutilisées lors de la phase d'exploitation et dans le rapport final du test d'intrusion. La machine virtuelle Windows 7 SP1 que j'ai créée servira de victime pour les prochains TP.